

CYBER SECURITY AUDIT REPORT

LEAFLY TEA

Target :

<https://leaflytea.in/>

Prepared for :

XQORA technologies

Prepared by :

Rudhresh Kumar S

Assessment Type:

In-Depth Security Audit

Assessment Approach:

Non-destructive Security Testing

Date:

September 2026

TABLE OF CONTENTS

- Executive Summary
- Scope of assessment
- Assessment Methodology
- Tools Used
- Reconnaissance
- Application Mapping
- HTTPS / TLS Assessment
- Burp Suite Assessment
- Security Headers Assessment
- Input Point Assessment
- Security Findings
- Recommendations
- Limitations
- Conclusion

1.EXECUTIVE SUMMARY

This report presents the results of non-destructive security audit performed on the Authorized target,

<https://leaflytea.in/>

The assessment focused on reconnaissance , application mapping ,HTTPS / TLS review , HTTP traffic inspection , security header review , and identification of user input points.

The purpose of the assessment was to identify security-related observations and document them with supporting evidence and recommendations.

2.SCOPE OF ASSESSMENT

Client:

XQORA Technologies

Authorized Target:

leaflytea.in

Target URL:

<https://leaflytea.in/>

Assessment Type:

In-Depth Security Audit

Testing Approach:

Non-Destructive Security Testing

Tester:

Rudhresh Kumar S

Scope Description

The assessment was limited to the authorized target, leaflytea.in, and focused on non-destructive security testing and documentation.

3. ASSESSMENT METHODOLOGY

The assessment included the following activities:

1. Reconnaissance
2. DNS and connectivity checks
3. HTTPS/TLS assessment
4. Manual application mapping
5. HTTP traffic inspection using Burp Suite
6. Security header review
7. Input-point identification
8. Evidence collection
9. Security findings documentation
10. Recommendations

4. TOOLS USED

The following tools and platforms were used during the security assessment:

1. Kali Linux

Used as the cybersecurity testing environment.

2. Firefox

Used to access and manually review the target website.

3. Burp Suite

Used to capture and inspect HTTP requests and responses.

4. OpenSSL

Used to review TLS and certificate information.

5. DNS utilities

Used for DNS and domain reconnaissance.

5. RECONNAISSANCE

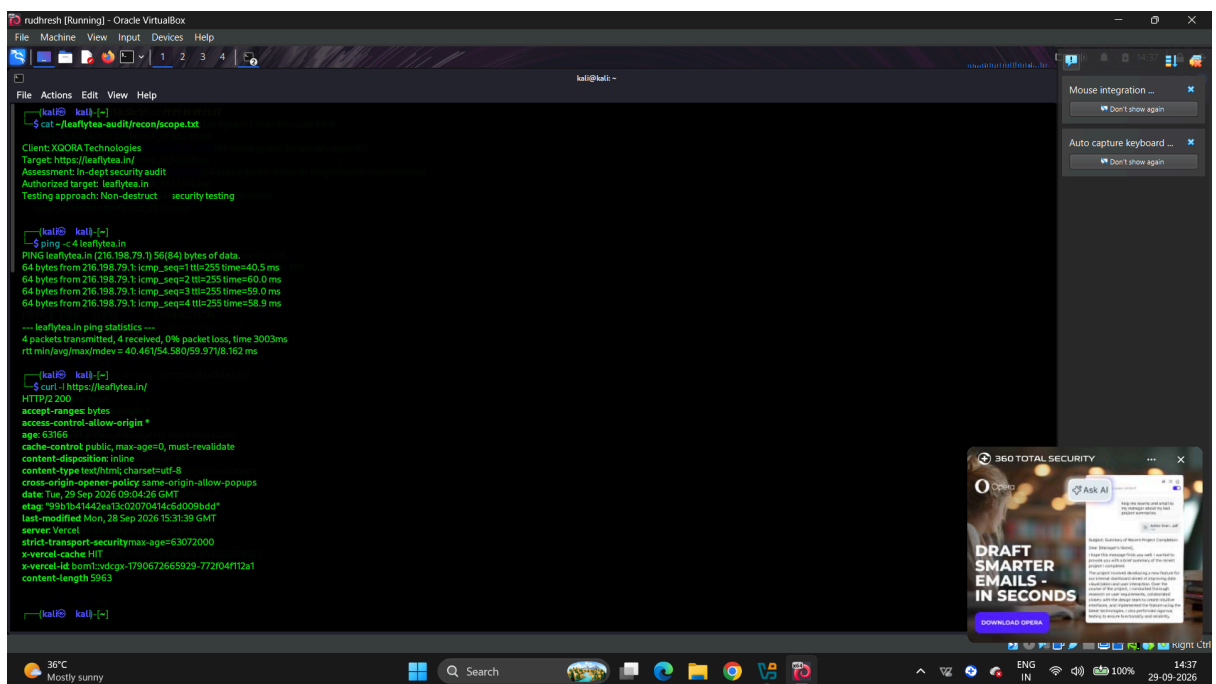
Initial reconnaissance was performed against the authorized target to collect basic domain and connectivity information. The activity was conducted using a non-destructive approach.

Target Domain:

leaflytea.in

Target URL:

<https://leaflytea.in/>



```
nrdhresh [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ dig leaflytea.in A

;<<>> DIG 9.20.0-Debian <<>> leaflytea.in A
;; global options: +cmd
;; Got answer:
;;->>HEADER<<- opcode: QUERY, status: NOERROR, id: 2708
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;leaflytea.in.      IN      A

;; ANSWER SECTION:
leaflytea.in.      3332   IN      A      216.198.79.1

;; Query time: 12 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Sep 29 14:36:05 IST 2026
;; MSG SIZE: rcvd: 46

kali@kali: ~
$ dig leaflytea.in MX

;<<>> DIG 9.20.0-Debian <<>> leaflytea.in MX
;; global options: +cmd
;; Got answer:
;;->>HEADER<<- opcode: QUERY, status: NOERROR, id: 44554
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1280
;; QUESTION SECTION:
;leaflytea.in.      IN      MX

;; AUTHORITY SECTION:
leaflytea.in.      600    IN      SOA     ns13.domaincontrol.com. dns.jomax.net. 202609120128800 7200 604800 600

;; Query time: 140 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Sep 29 14:36:13 IST 2026
;; MSG SIZE: rcvd: 112
```

```
nrdhresh [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ dig leaflytea.in NS

;<<>> DIG 9.20.0-Debian <<>> leaflytea.in NS
;; global options: +cmd
;; Got answer:
;;->>HEADER<<- opcode: QUERY, status: NOERROR, id: 61455
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1280
;; QUESTION SECTION:
;leaflytea.in.      IN      NS

;; ANSWER SECTION:
leaflytea.in.      3600   IN      NS      ns13.domaincontrol.com.
leaflytea.in.      3600   IN      NS      ns14.domaincontrol.com.

;; Query time: 92 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Sep 29 14:36:21 IST 2026
;; MSG SIZE: rcvd: 96

kali@kali: ~
$
```

```
nudhresh [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ dig leaflytea.in NS

;; AUTHORITY SECTION:
leaflytea.in.      600    IN     SOA     ns13.domaincontrol.com. dns.jomax.net. 2026091201 28800 7200 604800 600

;; Query time: 140 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Sep 29 14:36:13 IST 2026
;; MSG SIZE rcvd: 112

--[kali@ kali: ~]
$ dig leaflytea.in NS

;<>> DIG 9.20.0-Debian <>> leaflytea.in NS
;; global options: +cmd
;; Got answer:
;;->>HEADER<<- opcode: QUERY, status: NOERROR, id: 61455
;; flags: qr rd ra QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 1280
;; QUESTION SECTION:
; leaflytea.in.      IN     NS

;; ANSWER SECTION:
leaflytea.in.      3600   IN     NS      ns13.domaincontrol.com.
leaflytea.in.      3600   IN     NS      ns14.domaincontrol.com.

;; Query time: 92 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Sep 29 14:36:21 IST 2026
;; MSG SIZE rcvd: 96

--[kali@ kali: ~]
$ dig +short leaflytea.in
216.198.79.1

--[kali@ kali: ~]
$ dig +short klnce.edu
112.133.193.245

--[kali@ kali: ~]
$
```

```
nudhresh [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ nmap leaflytea.in

Starting Nmap 7.94SVN (https://nmap.org) 26-09-29 14:42 IST
Nmap scan report for leaflytea.in (216.19)
Host is up (0.035s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 5.41 seconds

--[kali@ kali: ~]
$
```

Observation: The `curl` command was used to inspect the HTTP response headers of the authorized target. The response returned an HTTP/2 200 status, indicating a successful HTTP response. Additional response headers such as `Accept-Ranges`, `Age`, and `Server` were also observed.

6. APPLICATION MAPPING

1. Public Pages

1. Home
2. Shop
3. Teaware
4. Tea Collection
5. Tea Maker
6. Why Leafly
7. Gifting
8. Journal

2. Authentication

1. Login: Yes
2. Create Account: Yes
3. Forgot Password: Yes

3. Input Points

1. Search: Yes
2. Contact Us: Yes
3. Login Form: Yes
4. Filters: Yes

4. Other Functionalities

1. Cart: Yes
2. Checkout: Yes
3. Registration Form: No

5. Interesting URLs

1. leaflytea.in/tea-maker
2. leaflytea.in/why-leafly
3. leaflytea.in/gifting

7. HTTPS/TLS ASSESSMENT

HTTPS was reviewed to examine the TLS certificate associated with the authorized target. OpenSSL was used to retrieve the certificate subject, issuer, and validity period.

Certificate Details:

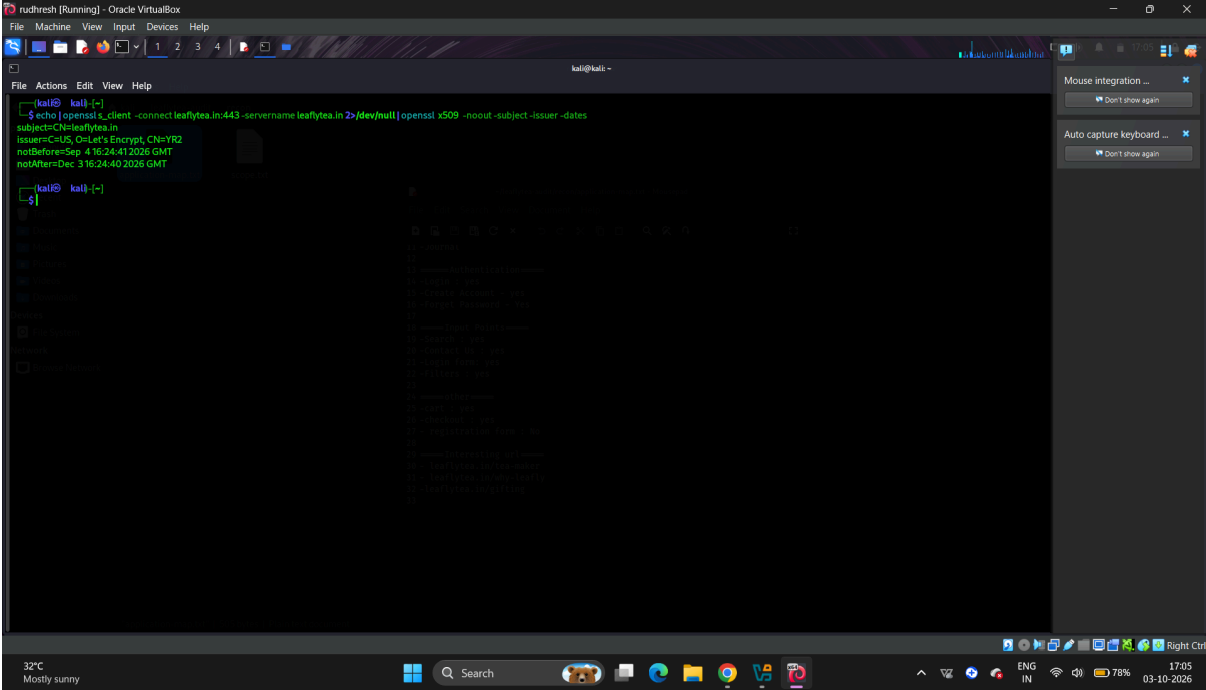
- Subject: **CN=leaflytea.in**
- Issuer: **C=US, O=Let's Encrypt, CN=R12**
- Valid From: **Sep 4 16:24:41 2026 GMT**
- Valid Until: **Dec 3 16:24:40 2026 GMT**

Observation:

The TLS certificate was successfully retrieved using OpenSSL. The certificate is issued to **leaflytea.in** by Let's Encrypt (R12) and has a defined validity period from September 4, 2026 to December 3, 2026.

Result:

The HTTPS certificate was successfully identified and its validity information was reviewed.



```
rudresh [Running] - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
File Actions Edit View Help

kali@kali:~$ echo | openssl s_client -connect leaflytea.in:443 -servername leaflytea.in 2>/dev/null | openssl x509 -noout -subject -issuer -dates
subject=CN=leaflytea.in
issuer=C=US, O=Let's Encrypt, CN=R12
notBefore=Sep 4 16:24:41 2026 GMT
notAfter=Dec 3 16:24:40 2026 GMT

kali@kali:~$
```

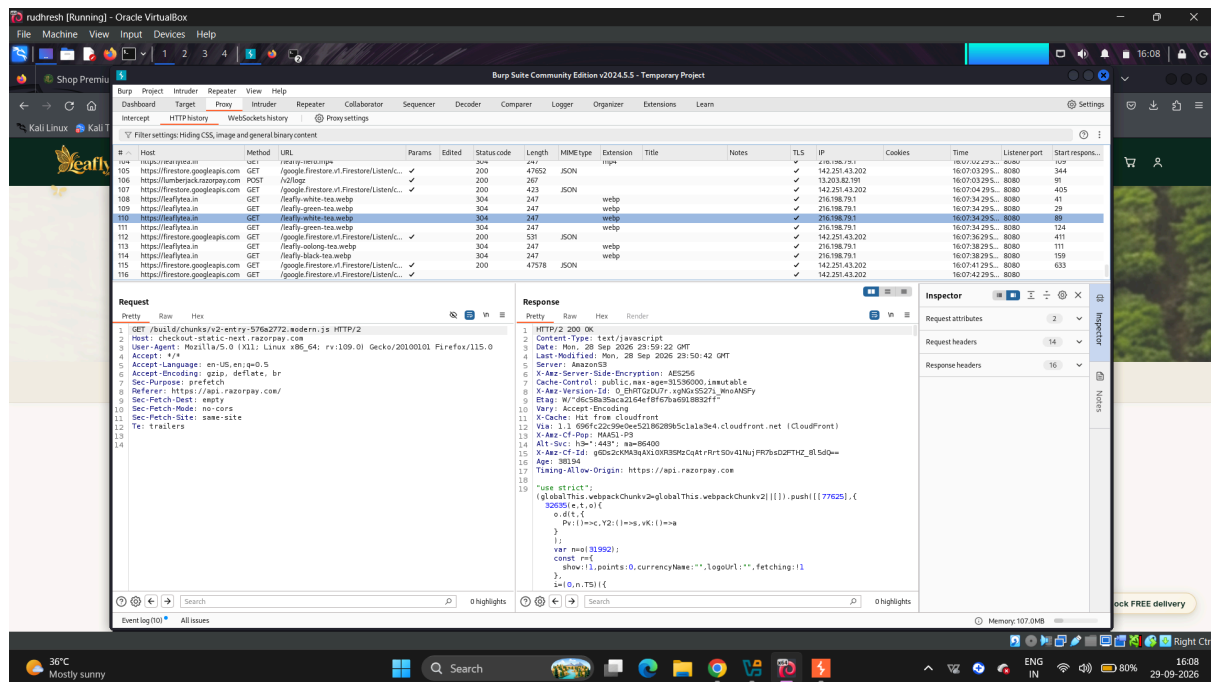
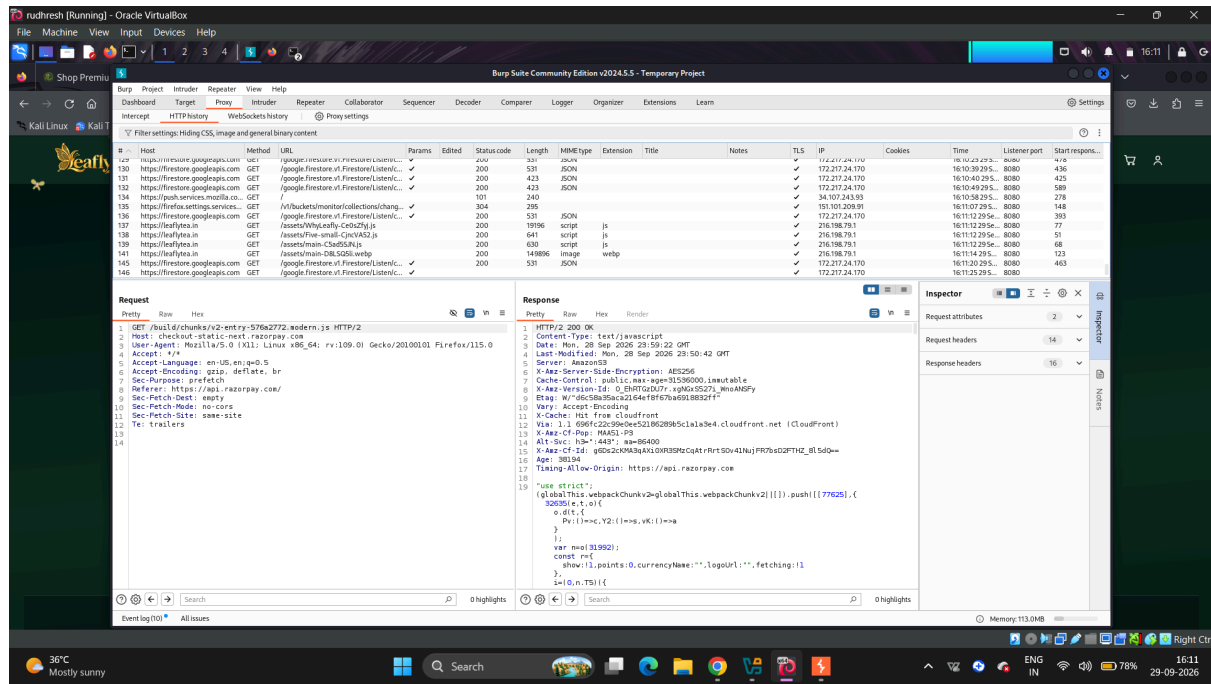
The screenshot shows a Kali Linux terminal window with the command `echo | openssl s_client -connect leaflytea.in:443 -servername leaflytea.in 2>/dev/null | openssl x509 -noout -subject -issuer -dates` and its output. The output displays the certificate details: subject **CN=leaflytea.in**, issuer **C=US, O=Let's Encrypt, CN=R12**, and validity dates **notBefore=Sep 4 16:24:41 2026 GMT** and **notAfter=Dec 3 16:24:40 2026 GMT**. The terminal window is titled 'rudresh [Running] - Oracle VirtualBox' and has a menu bar with 'File', 'Machine', 'View', 'Input', 'Devices', and 'Help'. The bottom status bar shows '32°C Mostly sunny', a search bar, and system icons for language (ENG IN), network, and battery (78%).

8. BURP SUITE ASSESSMENT

Burp Suite was used to capture and inspect HTTP/HTTPS traffic generated while accessing the authorized target website. The assessment focused on observing requests and responses without performing destructive testing.

Activities Performed

- Configured Burp Suite proxy listener on **127.0.0.1:8080**.
- Configured the browser to use the Burp Suite proxy.
- Accessed the authorized target website through the configured browser.
- Captured HTTP/HTTPS traffic using Burp Suite HTTP history.
- Reviewed requests and responses generated by the website.



The observation :

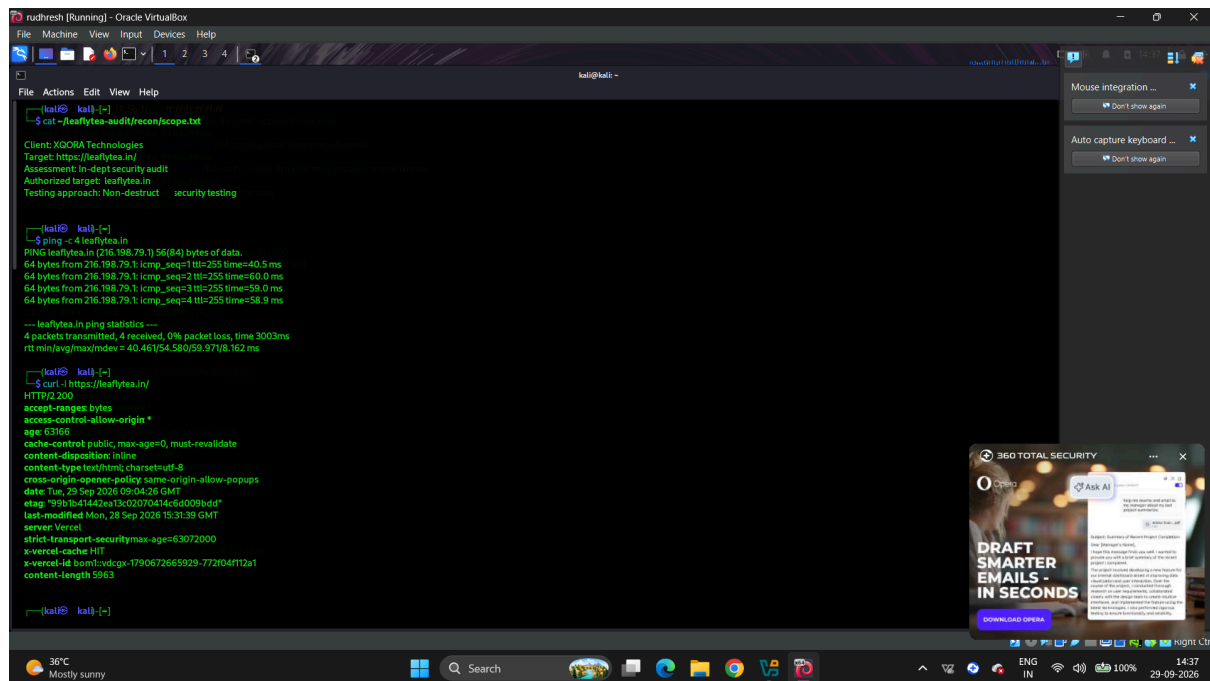
Burp Suite successfully captured HTTP/HTTPS traffic generated while browsing the authorized target. The HTTP history provided visibility into requests and responses exchanged between the browser and the web application.

Result :

HTTP traffic inspection was successfully performed using Burp Suite. No destructive actions or unauthorized exploitation were performed during this assessment.

9. SECURITY HEADERS ASSESSMENT

HTTP response headers were reviewed to identify security-related headers returned by the authorized target. The assessment was performed using `curl` and focused on observing the server response without modifying the application.



```
rudresh (Running) - Oracle VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ cat ~/leaflytea-audit/recon/scope.txt
Client: XOORA Technologies
Target: https://leaflytea.in/
Assessment: In-dept security audit
Authorized target: leaflytea.in
Testing approach: Non-destruct security testing

kali@kali: ~
$ ping -c 4 leaflytea.in
PING leaflytea.in (216.198.79.1) 56(84) bytes of data:
64 bytes from 216.198.79.1: icmp_seq=1 ttl=255 time=40.5 ms
64 bytes from 216.198.79.1: icmp_seq=2 ttl=255 time=60.0 ms
64 bytes from 216.198.79.1: icmp_seq=3 ttl=255 time=59.0 ms
64 bytes from 216.198.79.1: icmp_seq=4 ttl=255 time=58.9 ms

--- leaflytea.in ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3003ms
rtt min/avg/max/mdev = 40.461/54.580/59.971/8.162 ms

kali@kali: ~
$ curl -i https://leaflytea.in/
HTTP/2.0 200
accept-ranges: bytes
access-control-allow-origin: *
age: 63166
cache-control: public, max-age=0, must-revalidate
content-disposition: inline
content-type: text/html; charset=utf-8
cross-origin-opener-policy: same-origin-allow-popups
date: Tue, 29 Sep 2026 09:04:26 GMT
etag: "99b1b41442ea13c02070414c64009bdd"
last-modified: Mon, 28 Sep 2026 15:31:39 GMT
server: Vercel
strict-transport-security: max-age=63072000
x-vercel-cache: HIT
x-vercel-id: bom1:edge:1790672665929-772f04f112a1
content-length: 5963
```

Observation :

The HTTP response headers of the authorized target were inspected using `curl`. The response returned an HTTP 200 status, indicating a successful request. Various HTTP response headers were observed and reviewed for the presence of security-related controls.

10. INPUT POINT ASSESSMENT

The authorized web application was manually reviewed to identify user-controlled input points and interactive features. The assessment focused on identifying available input fields without performing destructive or unauthorized testing.

Identified Input Points:

Search - Yes

Contact us - Yes

Login Form - Yes

Filters - Yes

Observation :

Several user-interaction points were identified during manual application mapping. These included the search function, contact form, login form, and product filters. A registration form was not identified during the review.

Result :

The identified input points were documented for further security assessment. No destructive payloads or unauthorized exploitation were performed.

11. SECURITY FINDINGS

The following findings and observations were identified during the non-destructive security assessment of the authorized target. The findings are based on the reconnaissance, application mapping, TLS review, Burp Suite traffic inspection, and input-point assessment performed during the audit.

Finding 1 — Application Exposure

Observation:

The application provides several publicly accessible pages and features, including Shop, Teaware, Tea Collection, Tea Maker, Why Leafly, Gifting, Journal, cart, and checkout functionality.

Impact:

Publicly accessible functionality increases the application's attack surface and should be appropriately secured and monitored.

Recommendation:

Ensure that all publicly accessible pages and application functions are regularly reviewed for security issues and that access controls are correctly implemented where required.

Finding 2 — Authentication Functionality

Observation:

Login, account creation, and password recovery functionality were identified during application mapping.

Impact:

Authentication functionality should be protected against common account-security risks such as weak authentication controls and improper access control.

Recommendation:

Apply strong authentication controls, secure password handling, appropriate session management, and rate limiting where applicable.

Finding 3 — User Input Points**Observation:**

Search, Contact Us, Login Form, and Filters were identified as user interaction points.

Impact:

User-controlled inputs can require validation and secure handling to reduce the risk of input-related vulnerabilities.

Recommendation:

Apply appropriate server-side input validation, output encoding, and secure processing for all user-controlled input.

Conclusion:

No confirmed critical or high-severity vulnerability is reported in this section based solely on the completed non-destructive checks. Further controlled testing would be required to establish the presence of specific vulnerabilities.

12. RECOMMENDATIONS

Based on the observations made during the non-destructive security assessment, the following general security recommendations are provided.

Application Security

Regularly review publicly accessible pages and application functionality for security weaknesses. Ensure that access controls are correctly implemented for any restricted functionality.

Authentication Security

Apply strong password policies, secure authentication mechanisms, account protection controls, and appropriate rate limiting for login and password-recovery functionality.

Input Validation

Validate all user-controlled input on the server side and apply appropriate output encoding to reduce the risk of input-related vulnerabilities.

HTTPS/TLS

Maintain a valid TLS certificate and regularly review TLS configuration, supported protocols, and cipher suites to ensure secure encrypted communication.

HTTP Security Headers

Review and configure appropriate security-related HTTP headers based on the application's requirements, such as Content-Security-Policy, Strict-Transport-Security, and X-Content-Type-Options.

Continuous Security Testing

Perform periodic security assessments and vulnerability testing to identify newly introduced security issues after application updates or changes.

Monitoring

Maintain appropriate logging and monitoring for authentication activity, application errors, and suspicious requests to support timely detection and investigation of security events.

13. LIMITATIONS

The security assessment was performed using a non-destructive testing approach and was limited to the authorized target, leaflytea.in.

Assessment Limitations

- Testing was limited to the authorized target and its publicly accessible functionality.
- No destructive testing was performed.
- No denial-of-service or availability-impacting tests were performed.
- No brute-force or credential-attack activities were performed.
- The assessment was based on the application's observable behavior during the testing period.
- The assessment does not guarantee that all possible vulnerabilities were identified.
- Some security controls may require authenticated access or deeper testing to assess completely.

14. CONCLUSION

The security audit of the authorized target, <https://leaflytea.in/>, was completed using a non-destructive assessment approach. The assessment included reconnaissance, application mapping, HTTPS/TLS certificate review, Burp Suite traffic inspection, security header review, and identification of user input points.

The assessment helped document the application's publicly accessible functionality, authentication features, user input points, and basic security configuration observations. The collected evidence and recommendations can be used as a baseline for further security assessment and continuous improvement.

No critical or high-severity vulnerability is being claimed based solely on the checks documented in this report. Additional controlled testing would be required to determine whether specific vulnerabilities exist.

